VULNERABILITY ASSESSMENT

SOJOSPECT

v1.0.0

Scanned by: U0000028

13/11/2023

Scanned on: https://chmsdemo.greenfossil.com

GREENFOSSIL PTE LTD

Table of Contents

1. Executive Summary.....2

2. Scan Results 2

3. Our Findings.....2

4. Risk Assessment.....2

Critical Severity Vulnerability.....2

High Severity Vulnerability.....3

Medium Severity Vulnerability 3

Low Severity Vulnerability 3

5. Recommendations.....3

Remediation.....4

1. Executive Summary

This report provides an overview of the Vulnerability Test Assessment conducted for Greenfossils' Church Management System, addressing the OWASP Top 10 security risks. The assessment aims to identify and evaluate vulnerabilities in the company's web application and infrastructure which enables informed decision-making to enhance the overall security posture.

Scanned by: U0000028

Ommitted Scans:
Forced_browsing, injection,

Each risk category was examined thoroughly and vulnerabilities were identified and classified based on their severity. The key findings and recommendations from the assessment are summarized below. The vulnerabilities identified in the Vulnerability Test Assessment Suite for Greenfossils' digital assets pose significant risks to the company's operations, reputation, and bottom line. Ignoring or delaying the remediation of these vulnerabilities can lead to a range of detrimental business impacts.

2. Scan Results

The raw scan results will be provided upon delivery.

3. Our Findings

The results from the credentialed patch audit are listed below.

4. Risk Assessment

This report identifies security risks that could have significant impact on mission-critical applications used for day-to-day business operations.

Critical Severity	Medium Severity	Low Severity
0	1	3

High Severity Vulnerability

0 were unique high severity vulnerabilities. High severity vulnerabilities are often harder to exploit and may not provide the same access to affected systems.

Vulnerability ID	Vulnerability Name	Severity
CWE-425	Forced Browsing	Medium
CUST-robots	Lack of Robots.txt	Low
CWE-203	Overinformative Login Page	Low
CWE-1275-1004-614	Cookie without security attributes	Low
CAPAC-593	Session Hijacking	Medium

Medium Severity Vulnerability

1 were unique medium severity vulnerabilities. These vulnerabilities often provide information to attackers that may assist them in mounting subsequent attacks on your network. These should also be fixed in a timely manner but are not as urgent as the other vulnerabilities.

Vulnerability	Description	Solution
Session Hijacking	This type of attack involves an adversary that exploits weaknesses in an application's use of sessions in performing authentication. The adversary is able to steal or manipulate an active session and use it to gain unathorized access to the application.	Implement a unique token that would be sent along with the request, enable ...

Low Severity Vulnerability

3 were unique low severity vulnerabilities. These vulnerabilities are not as serious as other vulerabilities but might be used by attackers in rare cases.

Vulnerability	Description	Solution
Lack of Robots.txt	robots.txt is a necessary standard used by websites to communicate with web crawlers and other automated agents (like search engine bots) about which parts of the site should not be crawled or scraped.	Implement a unique token that would be sent along with the request, enable ...
Overinformative Login Page	Error messages are present that might provide data for attackers to use in the login page.	Implement a unique token that would be sent along with the request, enable ...
Cookie without security attributes	The product uses a cookie to store sensitive information, but the cookie is not marked with the HttpOnly flag, Secure flag, Samesite flag.	Implement a unique token that would be sent along with the request, enable ...

5. Recommendations

Recommendations in this report are based on the available findings from the credentialed patch audit. Vulnerability scanning is one of the many tools to assess the security posture of a network. The results should not be interpreted as definitive measurement of the security posture of the network. Other elements used to assess the current security posture would include policy review, a review of internal security controls and procedures, or internal red teaming/penetration testing.

Additional Resources

External sources are listed below which can help fix issues:

OWASP Top Ten - A standard awareness document for developers and web application security
Software Testing Help - A guide to OWASP Top 10 Security Vulnerabilities and mitigation strategies

TALK TO US

(65) 67751133
contactus@sp.edu.sg